

Gabriel Queiroz Teles - 2311064

Authentication, Broken Access Control

The screenshot shows the PortSwigger Web Security Labs interface. The left sidebar contains a list of topics, with 'Authentication' highlighted. The main content area displays the 'Authentication' section, which includes a list of labs. The first lab, 'Referer-based access control', is marked as 'Not solved'. Below it, several other labs are listed, including 'Username enumeration via different responses', '2FA simple bypass', 'Password reset broken logic', 'Username enumeration via subtly different responses', 'Username enumeration via response timing', and 'Referer-based access control' (repeated). The status of each lab is indicated by a 'Solved' or 'Not solved' button.

Lab Title	Level	Status
Referer-based access control	Practitioner	Not solved
Username enumeration via different responses	Apprentice	Solved
2FA simple bypass	Apprentice	Solved
Password reset broken logic	Apprentice	Solved
Username enumeration via subtly different responses	Practitioner	Not solved
Username enumeration via response timing	Practitioner	Not solved
Referer-based access control	Practitioner	Not solved

The screenshot shows the PortSwigger Web Security Labs interface. The left sidebar contains a list of topics, with 'Access control vulnerabilities' highlighted. The main content area displays the 'Access control vulnerabilities' section, which includes a list of labs. The first lab, 'File path traversal, validation of file extension with null byte bypass', is marked as 'Not solved'. Below it, several other labs are listed, including 'Unprotected admin functionality', 'Unprotected admin functionality with unpredictable URL', 'User role controlled by request parameter', 'User role can be modified in user profile', 'User ID controlled by request parameter', 'User ID controlled by request parameter, with unpredictable user IDs', 'User ID controlled by request parameter with data leakage in redirect', 'User ID controlled by request parameter with password disclosure', 'Insecure direct object references', and 'URL-based access control can be circumvented'. The status of each lab is indicated by a 'Solved' or 'Not solved' button.

Lab Title	Level	Status
File path traversal, validation of file extension with null byte bypass	Practitioner	Not solved
Unprotected admin functionality	Apprentice	Solved
Unprotected admin functionality with unpredictable URL	Apprentice	Solved
User role controlled by request parameter	Apprentice	Solved
User role can be modified in user profile	Apprentice	Solved
User ID controlled by request parameter	Apprentice	Solved
User ID controlled by request parameter, with unpredictable user IDs	Apprentice	Solved
User ID controlled by request parameter with data leakage in redirect	Apprentice	Solved
User ID controlled by request parameter with password disclosure	Apprentice	Solved
Insecure direct object references	Apprentice	Solved
URL-based access control can be circumvented	Practitioner	Not solved

OWASP Juice Shop

http://localhost:3000/#/score-board?categories=Broken Access Control

12%
Hacking Challenges

0%
Coding Challenges

13/172
Challenges Solved

4/28 5/23 3/44
1/37 0/26 0/14

Search

Difficulty

Status

Tags

All XSS Sensitive Data Exposure Improper Input Validation Broken Access Control Unvalidated Redirects Vulnerable Components Broken Authentication Security through Obscurity Insecure Deserialization Miscellaneous Broken Anti Automation Injection Security Misconfiguration Cryptographic Issues XXE

Broken Access Control

Web3 Sandbox

Find an accidentally deployed code sandbox for writing smart contracts on the fly.

Web3 With Coding Challenge

0/1

Broken Access Control

Admin Section

Access the administration section of the store.

Good for Demos With Coding Challenge

0/3

Broken Access Control

View Basket

View another user's shopping basket.

Tutorial Good for Demos

0/3

Broken Access Control

Five-Star Feedback

Get rid of all 5-star customer feedback.

0/2

Broken Access Control

Forged Feedback

Post some feedback in another user's name.

Tutorial

0/3

Broken Access Control

CSRF

Change the name of a user by performing Cross-Site Request Forgery from another origin.

0/4

Broken Access Control

Forged Review

Post a product review as another user or edit any user's existing review.

With Coding Challenge

0/4

Broken Access Control

Manipulate Basket

Put an additional product into another user's shopping basket.

0/3

Broken Access Control

Product Tampering

Change the href of the link within the OWASP SSL Advanced Forensic Tool (O-Saft) product description into https://owasp.slack.com.

With Coding Challenge

0/2

Broken Access Control

Easter Egg

Find the hidden easter egg.

Shareanagram Contraption Good for Demos

0/2

Broken Access Control

SSRF

Request a hidden resource on server through server.

Code Analysis

0/4

OWASP Juice Shop

Account EN

13%
Hacking Challenges

0%
Coding Challenges

14/172
Challenges Solved

4/28 6/23 3/44
1/37 0/26 0/14

Search

Difficulty

Status

Tags

All XSS Sensitive Data Exposure Improper Input Validation Broken Access Control Unvalidated Redirects Vulnerable Components Broken Authentication Security through Obscurity Insecure Deserialization Miscellaneous Broken Anti Automation Injection Security Misconfiguration Cryptographic Issues XXE

Broken Authentication

Password Strength

Log in with the administrator's user credentials without

Brite Force Tutorial With Coding Challenge

0/4

Broken Authentication

Bjoern's Favorite Pet

Reset the password of Bjoern's OWASP account via the Forgot Password mechanism with the original answer to his security question.

OSINT With Coding Challenge

0/3

Broken Authentication

GDPR Data Erasure

Log in with Chris' erased user account.

0/4

Broken Authentication

Reset Jim's Password

Reset Jim's password via the Forgot Password mechanism with the original answer to his security question.

OSINT With Coding Challenge

0/4

Broken Authentication

Login Bjoern

Log in with Bjoern's Gmail account without previously changing his password, applying SQL Injection, or hacking his Google account.

Code Analysis

0/4

Broken Authentication

Reset Bender's Password

Reset Bender's password via the Forgot Password mechanism with the original answer to his security question.

OSINT With Coding Challenge

0/3

Broken Authentication

Change Bender's Password

Change Bender's password into slurmC4ssic without using SQL Injection or Forgot Password.

0/3

Broken Authentication

Reset Bjoern's Password

Reset the password of Bjoern's internal account via the Forgot Password mechanism with the original answer to his security question.

OSINT With Coding Challenge

0/3

Broken Authentication

Two Factor Authentication

Solve the 2FA challenge for user "wurstbrot". (Disabling, bypassing or overwriting his 2FA settings does not count as a solution)